

「전자의무기록의 관리·보존에 필요한 시설과 장비에 관한 기준」 고시 개정(안) 보고

(‘23.11.7(화), 의료정보정책과)

□ 추진배경

- 의료법*에 따라 의료기관 외부에 전자의무기록을 보관하는 경우 안전한 관리·보존을 위해 네트워크 보안, 시스템 보안 등 추가적인 조치** 규정

* 의료법 제23조 제2항, 의료법 시행규칙 제16조

** 예) 이중화된 네트워크, 인증받은 정보보호·보안 제품 도입, 출입 통제 구역설치, 전자의무기록 시스템 및 백업 장비의 물리적 위치 국내 한정 등

- 최근 국·내외 보안인증을 받은 클라우드 기반 EMR 시스템 사용이 증가하면서 인증기준과 고시 지표의 유사·중복 규정*에 대한 지적**

* 예) ISMS, ISO27001 인증 통해 안전한 암호화 기술을 인정받은 클라우드에 전자 의무기록을 보관하려면 CC인증을 받은 암호화 제품의 추가적 도입 필요

** (주한미국상공회의소) 외국기업 시장진입을 차단하는 차별적 조항 개선 요청(‘20년)
(관계부처 합동)바이오헬스 신산업 규제혁신 과제(‘22년)

- 국·내외 보안인증*을 받은 클라우드에 전자의무기록을 보관하는 경우 시설과 장비에 대한 보안 규정과의 유사·중복 규제를 합리적으로 개선 필요

* ▲클라우드컴퓨팅서비스의 정보보호에 관한 기준

▲정보통신망법 제47조에 따른 정보보호 관리체계 인증(ISMS)

▲클라우드 서비스 정보보호인증(ISO27017) 및 개인정보보호관리체계 인증(ISO27018)

□ 추진경과

- 외부보관 EMR 인증 가이드라인 개발 연구 진행 (‘22.1월)
 - 고시 내 규정과 국·내외 보안인증 기준을 비교 유사·중복 기준 확인 및 부합되는 기준이 없어 별도 규정이 필요한 항목* 확인

* 네트워크 이중화 및 시설·장비의 물리적 위치를 국내로 한정

- 내부적으로 CSAP 인증기준 변경사항 및 개인정보 보호법 개정안 검토 진행 (‘23.6월)

- 해외 CSP(아마존) 두 차례 의견 청취 ('23.7월)
 - 현재 2단계 암호화 방식 등 고안정성 보안서비스를 제공하고 있는 상태에서 CC인증 암호모듈 사용만을 규정하는 것은 클라우드 환경에 부적합하고 불합리하다는 의견 제시
- 클라우드 EMR 관련 전문가* 자문회의 ('23.8월)
 - * ISO/TC 215 WG4 전문위원, GDHP 사이버보안분과 위원장, 한국디지털인증협회 회장, ISMS-P 인증심사원
 - 클라우드EMR의 CC인증/검증필 암호모듈 등 유사·중복 규제를 개선할 때 고려사항 및 안전성 보증방안 검토

□ 주요 개정(안)

- 국·내외 보안인증을 획득한 클라우드 기반 전자의무기록 시스템의 경우 보안 관련 유사·중복 규정은 제외하고 이중화된 네트워크, 물리적 위치 한정 요건만을 적용하도록 개정(제7조 제2항 신설)

□ 추진 계획

- 개정안 부내 협의 및 체계·심사 (~ 11월15일)
- 부처안 확정 (~ 11월17일)
- 규제심사대상 사전협의 (~ 11월23일)
- 행정예고 및 관계부처 협의 (11월24일 ~ 12월13일)
- 개정안 발령 (~ 12월15일)

현행	개정안
제7조(의료기관 외의 장소 관리·보존시 추가적인 조치) 전자의무기록 관리자가 의료기관 외의 장소에서 전자의무기록을 관리·보존하는 경우에는 규칙 제16조제1항제3호부터 제7호까지에 따른 시설과 장비에 대하여 <u>별표</u> 에 따른 추가적인 조치를 하여야 한다. <u><신 설></u>	제7조(의료기관 외의 장소 관리·보존시 추가적인 조치) ① ----- ----- ----- ----- ----- <u>별표 1</u> ----- -----. ② 제1항에도 불구하고 다음 각 호의 어느 하나를 충족하는 클라우드컴퓨팅서비스를 이용하여 전자의무기록을 관리하는 자가 <u>별표 2</u> 에 따른 조치를 하면 <u>별표 1</u> 에 따른 조치를 한 것으로 간주한다. 1. 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 제47조에 따른 정보보호 관리체계 인증과 국제표준화기구 및 국제전기기술위원회(ISO/IEC)의 클라우드 서비스 정보보호 관리체계 인증을 받은 서비스 2. 「클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률」 제23조제2항에 따른 클라우드컴퓨팅

	<u>서비스의 정보보호에 관한 기준</u> <u>을 충족하는 서비스</u>
--	--

[별표 2] 클라우드컴퓨팅서비스 정보보호에 관한 요건 충족 시 필요한 추가적인 조치

구 분		세 부 조 치 내 용
2. 네트워크 보안에 관한 시설과 장비	2.1. 이중화된 네트워크의 구성	- 의료데이터 전송을 위한 이중화된 네트워크를 구성하여야 하며 아래 조건을 충족하여야 한다. · 물리적 또는 그에 준하는(논리적 포함) 둘 이상의 회선 분리 · 둘 이상의 경로를 제공하는 내부망 구성 · 라우터의 이중화 구성 · 장애발생 시에도 지속적인 서비스 제공 대책 수립
4. 전자의무 기록 보존장소에 대한 물리적 접근방지 시설과 장비	4.3. 물리적 위치의 한정	- 전자의무기록 시스템 및 그 백업장비의 물리적 위치는 국내로 한정한다.